

Information Security Policy

NOVAtech Inc. | Simulated for demonstration

Document	Information Security Policy
Version	1.0
Owner	Chief Technology Officer
Approved by	Chief Technology Officer
Effective date	2026-08-03
Next review	Annually
Applies to	All employees, contractors, and third parties with access to NOVAtech information systems
Framework alignment	ISO/IEC 27001:2022 Clause 5.2; A.5.1 (Policies for information security)

1. PURPOSE

This policy establishes management direction and support for information security at NOVAtech in accordance with business requirements, applicable laws and regulations, and contractual commitments to customers. It defines the principles that govern how NOVAtech protects the confidentiality, integrity, and availability of information assets, and establishes the authority for supporting standards and procedures.

2. SCOPE

This policy applies to all information assets within the NOVAtech ISMS scope as defined in the ISMS Scope Statement, and to all employees, contractors, and third parties who access, process, or store NOVAtech information. It covers information in all forms and all stages of its lifecycle: creation, storage, transmission, use, and disposal.

3. POLICY STATEMENTS

3.1 Information classification and handling

Information shall be classified according to its sensitivity and business value, and protected in accordance with its classification throughout its lifecycle. NOVAtech's classification scheme comprises four levels: Restricted, Confidential, Internal, and Public. Handling requirements for each classification are defined in the Data Classification Standard.

3.2 Access control

Access to information and information systems shall be granted on the principles of least privilege and need-to-know. All access shall be individually attributable, formally approved before provisioning, reviewed periodically, and removed promptly when no longer required. Detailed requirements are defined in the Access Control Policy and Standard.

3.3 Risk management

Information security risks shall be systematically identified, assessed against defined criteria, and treated in accordance with NOVAtech's risk appetite. Every risk shall have a named business owner. Risks accepted rather than mitigated shall be formally documented, approved by an appropriate authority, and reviewed at defined intervals. The enterprise risk register is the authoritative record.

3.4 Security by design

Information security requirements shall be identified and incorporated at the outset of projects, system changes, and supplier engagements, rather than retrofitted. Security review shall be a gate in the development lifecycle for material changes to systems handling Confidential or Restricted information.

3.5 Personnel security and awareness

All personnel shall complete information security awareness training at onboarding and annually thereafter. Training completion shall be tracked and reported, with escalation to managers where completion falls below target. Personnel with privileged access or specialized responsibilities shall receive role-appropriate additional training.

3.6 Incident management

Suspected information security incidents and weaknesses shall be reported immediately through defined channels. NOVAtch operates a documented incident response process covering preparation, assessment, response, and learning. Personnel who report suspected incidents in good faith shall not face retaliation, including where the report concerns their own error.

3.7 Business continuity

Continuity of critical business services shall be planned, documented, and tested. Recovery objectives shall be derived from business impact analysis and validated through periodic testing. Backup and recovery capabilities shall be maintained commensurate with the criticality of each service.

3.8 Supplier and third-party security

Third parties handling NOVAtch or customer information shall be assessed proportionate to the risk they present, bound by contractual security and privacy obligations, and monitored through the life of the engagement. Vendor tiering determines assessment depth and reassessment frequency.

3.9 Legal, regulatory, and contractual compliance

NOVAtch shall identify and comply with applicable legal, regulatory, and contractual requirements relating to information security and privacy, including PIPEDA and applicable provincial privacy legislation. Compliance obligations shall be documented and reviewed as the regulatory environment changes.

3.10 Continual improvement

The ISMS shall be continually improved through monitoring, measurement, internal audit, management review, and corrective action arising from incidents, nonconformities, and changes in the threat or business environment.

4. ROLES AND RESPONSIBILITIES

Role	Responsibility
Chief Technology Officer	Accountable executive for information security. Approves this policy and the ISMS scope; chairs management review; allocates resources.
Head of Security	Owns the ISMS day-to-day. Maintains supporting policies and standards, operates the risk process, reports metrics to leadership.
GRC function	Maintains documented information, coordinates internal audit, tracks corrective actions, manages the exception and vendor registers.
Managers	Enforce this policy within their teams; ensure staff complete required training; approve access requests for their reports.
All personnel	Comply with this policy and supporting standards; report suspected incidents and weaknesses promptly; complete required training.

5. EXCEPTIONS

Exceptions to this policy or its supporting standards shall be requested in writing, include business justification and compensating controls, be approved by the Head of Security (or the CTO where the exception exceeds 90 days), and carry a defined expiry date. Approved exceptions shall be recorded in the Exception Register and reviewed monthly. No exception shall be open-ended.

6. COMPLIANCE AND ENFORCEMENT

Compliance with this policy is mandatory. Violations shall be investigated and may result in disciplinary action up to and including termination of employment or contract, and where applicable, referral to law enforcement. Nonconformities identified through audit or monitoring shall be tracked to closure through the corrective action process.

7. SUPPORTING DOCUMENTS

- Access Control Policy and Standard
- Acceptable Use Policy
- Vulnerability Management Policy and Standard

- Data Classification Standard
- Incident Response Plan
- ISMS Scope Statement and Statement of Applicability
- Business Impact Analysis

8. CHANGE HISTORY

v1.0 (issued 2026-08-03): initial policy establishing management direction for information security, supporting standards authority, and the exception framework.